JWT

JSON Web Token

A practical guide to token-based authentication



What is JWT?

A compact, URL-safe token format used to represent claims between parties. It is commonly used to support authentication and authorization workflows.

Anatomy of a JWT

xxxxx . **yyyyy** . **zzzzz**

HEADER

Token type and signing algorithm.

PAYLOAD

Claims such as subject, role, issuer, and expiration.

SIGNATURE

Used to verify token integrity and authenticity.

Authentication Flow

01 **Login** → 02 **Validate Credentials** → 03 **Issue Token** → 04 **Send Bearer Token** → 05 **Validate Token** → 06 **Access Protected Resource**

Security Essentials

1. Validate the signature and expiration.
2. Never store secrets in the payload.
3. Use HTTPS and protect token storage.
4. Plan token expiration, refresh, and revocation.